ARNOBOT

Hoe wij jouw gegevens beschermen

Een overzicht van de technische maatregelen die ArnoBot heeft getroffen om jouw privacy en de veiligheid van jouw data te waarborgen.

Versie 1.6 · 1 november 2026 · privacy@arno.bot

Vertrouwen is de basis van alles wat ArnoBot doet. Jij deelt persoonlijke inzichten, zakelijke uitdagingen en coachingsgesprekken met ons platform. Het is onze verantwoordelijkheid om die informatie te behandelen met de grootst mogelijke zorg. Dit document legt uit hoe wij dat technisch hebben ingericht.

WAAR JOUW GEGEVENS STAAN

Infrastructuur en hosting

ArnoBot maakt gebruik van gevestigde, gecertificeerde partijen voor alle infrastructurele onderdelen. Wij beheren zelf geen servers.

Onderdeel	Partij en garantie
Hosting	Vercel: serverless, wereldwijd CDN, HTTPS verplicht op alle verbindingen
Database	Supabase: PostgreSQL in de EU, versleuteld in rust (AES-256) en tijdens transport (TLS 1.2+)
Authenticatie	Clerk: SOC 2 Type II gecertificeerd, LinkedIn OAuth
AI-verwerking	Anthropic: jouw berichten worden verwerkt om een antwoord te genereren en daarna niet permanent opgeslagen
Spraakverwerking	OpenAI: spraakherkenning, verwerkt audio van voice-invoer, geen training op jouw data
Audiobijlage-transcriptie	AssemblyAI: spraaktranscriptie bij een audiobijlage, opname direct verwijderd, geen training op jouw data
Spraaksynthese (ArnoBot Voice)	ElevenLabs: tekst-naar-spraak voor ArnoBot Voice-abonnees, verwerkt gesproken antwoorden, geen training op jouw data
E-mail	

	Resend: transactionele e-mail en blogmails via DKIM-geverifieerde domeinen. Bij blogmails wordt gemeten of een mail wordt geopend en op welke links wordt geklikt
AI-kennisbank	Voyage AI: embeddings en herrangschikking voor de kennisbank en sessiegeheugen
Foutmonitoring	Sentry: foutmonitoring en performance-tracing
Snelheidslimieten	Upstash: rate limiting, verwerkt IP-adressen
Gebruiksanalyse	PostHog: bezoekers- en productgebruiksanalyse, pseudoniem voor ingelogde gebruikers, EU-hosting (Frankfurt)
Afspraken	Calendly: boeken van een kennismakingsgesprek met Arno, koppelt de boeking aan je e-mailadres
Betalingen	Mollie: online betalingen (iDEAL, Bancontact, creditcard), kaart- en bankgegevens gaan rechtstreeks naar Mollie en worden door ArnoBot nooit opgeslagen
Facturen en boekhouding	Moneybird: facturen en administratie, opslag binnen de EER, verwerkersovereenkomst afgesloten
Support (optioneel)	Meta Platforms (WhatsApp): support via de optionele WhatsApp-knop, verwerkt telefoonnummer en berichtinhoud

WIE ER BIJ KAN

Authenticatie en toegangsbeheer

Toegang tot jouw data is strikt beperkt tot jou. Wij hebben het volgende ingericht:

- **Inloggen via LinkedIn OAuth** Wij slaan nooit een wachtwoord op. Authenticatie verloopt via Clerk met kortlevende JWT-tokens.
- **Sessiecontrole op elke route** Elke API-aanroep verifieert eerst de actieve sessie. Routes zonder geldig token geven een 401-fout en stoppen direct.
- **Databasetoegang afgeschermd** De sleutel met volledige databaserechten is uitsluitend beschikbaar op de server en nooit zichtbaar in de browser.
- **Strikt gescheiden admintoegang** Beheerdersfuncties zijn beveiligd met een aparte sleutel die niet via de normale inlogflow bereikbaar is.

JOUW DATA IS VAN JOU

Gegevensisolatie

Een veelvoorkomende kwetsbaarheid is dat een gebruiker toegang krijgt tot andermans data door een parameter in de URL aan te passen. Dit heet IDOR (Insecure Direct Object Reference). ArnoBot beschermt hier actief tegen.

> Elke API-route haalt jouw identiteit op uit de geverifieerde sessie. Een gebruikers-ID in een URL of requestbody wordt nooit vertrouwd. Alleen de actieve sessie bepaalt welke data wordt teruggegeven.

- **Exportfunctie** Het downloaden van jouw gegevens werkt op basis van jouw ingelogde sessie, nooit op basis van een ID in de URL.
- **Teamdata** Een manager ziet uitsluitend data van leden die aantoonbaar tot hetzelfde team behoren.

INVOERBEVEILIGING

Wat er met jouw tekst gebeurt

- **Lengtelimieten** Chatberichten max 4.000 tekens, oefengesprekken max 2.000 tekens, vrije invoervelden max 500 tekens.
- **Sanitatie** Tekst die wordt doorgestuurd naar externe diensten wordt eerst ontdaan van tekens die tot injectie kunnen leiden.
- **E-mailvalidatie** E-mailadressen worden gecontroleerd op geldigheid voordat ze worden verwerkt of opgeslagen.

AANVALLEN VOORKOMEN

Wat er op ons afkomt en hoe wij het stoppen

Onderstaand overzicht laat zien welke aanvalstypen wij tegenkomen en welke maatregel precies wat afdekt.

Aanval	Hoe ArnoBot dit afdekt
Volumetrische aanvallen	Vercel Edge Network absorbeert grote hoeveelheden verkeer automatisch op netwerkniveau
API-misbruik	Maximaal 5 chatverzoeken per IP per minuut; admin-login geblokkeerd na 10 mislukte pogingen per 15 minuten
Prompt injection	13 detectiepatronen onderscheppen pogingen om het AI-model te manipuleren of data te ontfutselen
Bots en scanners	Middleware blokkeert automatisch bekende scannerpaden: .env, .git, wp-admin, phpMyAdmin en vergelijkbare paden
SQL-injectie	Supabase gebruikt geparametriseerde queries; Row Level Security begrenst bovendien wat elke gebruiker mag opvragen
Cross-site scripting	Content-Security-Policy headers beperken welke scripts de browser mag uitvoeren
Credential stuffing	Inloggen zonder wachtwoord via LinkedIn OAuth. Er valt niets te raden of te stelen.
Informatielekken	Technische foutdetails worden nooit aan de gebruiker getoond, alleen server-side gelogd
IDOR	Gebruikers-ID altijd uit de geverifieerde sessie, nooit uit URL of requestbody

BEVEILIGING IN DE BROWSER

HTTP-beveiligingsheaders

Elke pagina van ArnoBot wordt geserveerd met beveiligingsheaders die de browser instrueert hoe hij de inhoud moet behandelen.

- **X-Frame-Options: DENY** Voorkomt dat ArnoBot in een verborgen iframe op een andere site kan worden geladen (clickjacking).
- **X-Content-Type-Options: nosniff** Voorkomt dat de browser bestanden als een ander type interpreteert dan bedoeld.
- **Strict-Transport-Security** Dwingt de browser om altijd HTTPS te gebruiken, ook als je per ongeluk http:// typt.
- **Content-Security-Policy** Beperkt welke externe bronnen de browser mag laden.
- **Permissions-Policy** Schakelt camera, microfoon en locatietoegang uit. ArnoBot gebruikt deze features niet.
- **X-Powered-By verborgen** De technologie achter ArnoBot wordt niet bekendgemaakt aan derden.

SOFTWAREKWALITEIT

Afhankelijkheden en updates

Moderne webapplicaties zijn opgebouwd uit externe softwarepakketten. Kwetsbaarheden daarin kunnen ook jouw data raken. ArnoBot houdt dit actief bij.

- **Regelmatige audit** Alle pakketten worden gecontroleerd op bekende kwetsbaarheden. Kwetsbaarheden in runtime-code worden direct verholpen.
- **Nul bekende runtime-kwetsbaarheden** Na de laatste securitysessie zijn alle kwetsbaarheden in code die in productie draait verholpen.
- **Tijdslimiet op AI-aanroepen** Alle verbindingen met het AI-model hebben een maximale looptijd om onge-controleerd resourcegebruik te voorkomen.
- **Automatische monitoring** Dependabot controleert wekelijks alle pakketten op nieuwe kwetsbaarheden en meldt dit direct.

JOUW RECHTEN

Inzage, export en verwijdering

Op grond van de AVG heb je de volgende rechten, direct uitoefenbaar vanuit jouw account:

- **Recht op inzage (art. 15)** Download al jouw opgeslagen gegevens via Accountinstellingen, sectie Jouw data.
- **Recht op verwijdering (art. 17)** Verzoek tot verwijdering via Accountinstellingen, sectie Account verwijderen. Handmatig verwerkt binnen de wettelijke termijn.
- **Recht op rectificatie (art. 16)** Pas je profiel aan via de profielpagina.
- **Datalekken** In geval van een datalek word je binnen 72 uur geïnformeerd via het e-mailadres dat aan jouw account is gekoppeld.

CONTACT

Vragen over jouw data

Heb je vragen over hoe ArnoBot met jouw gegevens omgaat, of wil je een van jouw AVG-rechten uitoefenen?

> **privacy@arno.bot**
> Verzoeken worden binnen 10 werkdagen beantwoord.